

LAPORAN PROGRES
MINGGU KE – 2
Mata Kuliah Secure Software Engineering



Dosen Pengampu :
Septian Geges, S.Kom., M.Kom.

Disusun Oleh :

Hessel Josef Imanuel	2330205030062
Apreldiovano Brian Walmaputra	2330305030089
Rafael Sanjaya	2330305030075
Yohanes Abel Kelvin	2330205030051

JURUSAN TEKNIK INFORMATIKA
FAKULTAS TEKNIK
UNIVERSITAS PALANGKA RAYA
2026

DAFTAR ISI

DAFTAR ISI	i
BAB I PENDAHULUAN	1
1.1 Latar Belakang	1
1.2 Tujuan	1
BAB II PEMBAHASAN	3
2.1 Struktur Branch dan Repository	3
2.2 Struktur Folder Proyek	3
2.3 Tampilan Program	4
2.4 Implementasi Autentikasi Login dan Register	9
2.5 Implementasi Password Hashing	10
2.6 Implementasi Manajemen Sesi	10
2.7 Implementasi CSRF Protection	11
2.8 Implementasi Role-Based Access Control	12
2.9 Implementasi Validasi Input	12
2.10 Implementasi Rate Limiting Login	13
2.11 Pencegahan SQL Injection	15
2.12 Implementasi Stored Procedure Booking Aman	15
2.13 Integrasi Payment Gateway Midtrans	16
2.14 Implementasi Security Headers	17
2.15 Pencegahan Cross-Site Scripting	17
2.16 Secure Error Handling	18
2.17 Secure Code Review	18
2.18 Checklist Secure Coding Minggu 2	21
2.19 Hambatan dan Solusi	22
2.20 Lampiran	22
BAB III KESIMPULAN	23

BAB I

PENDAHULUAN

1.1 Latar Belakang

Pada minggu kedua proyek Secure Software Engineering, pengembangan sistem LuxeBooking difokuskan pada implementasi fitur keamanan inti. Sistem LuxeBooking merupakan aplikasi booking hotel berbasis web yang memiliki dua jenis pengguna utama, yaitu admin dan customer. Karena sistem ini menangani data akun pengguna, data booking, data transaksi, serta integrasi dengan payment gateway, maka aspek keamanan perlu diterapkan sejak tahap implementasi.

Materi minggu kedua menekankan beberapa kontrol keamanan utama, yaitu password hashing, autentikasi dan manajemen sesi, Role-Based Access Control, validasi input, pencegahan SQL Injection dan XSS, penggunaan security headers, CSRF protection, secure error handling, serta secure code review. Oleh karena itu, progress minggu kedua diarahkan untuk memastikan sistem tidak hanya berjalan secara fungsional, tetapi juga memiliki dasar keamanan yang sesuai dengan prinsip Secure Software Engineering.

Selain itu, pada minggu kedua juga dilakukan peningkatan manajemen sesi dengan memindahkan token autentikasi dari sessionStorage ke cookie HttpOnly, menambahkan atribut SameSite=Lax, serta menerapkan CSRF token untuk memvalidasi request penting. Peningkatan ini dilakukan agar sistem memiliki perlindungan yang lebih baik terhadap pencurian token melalui XSS dan serangan Cross-Site Request Forgery.

1.2 Tujuan

Tujuan dari progress minggu kedua adalah sebagai berikut:

1. Mengimplementasikan fitur autentikasi login dan register pada sistem LuxeBooking.
2. Menerapkan penyimpanan password menggunakan metode hashing bcrypt.
3. Mengimplementasikan manajemen sesi berbasis token.
4. Menerapkan pembatasan hak akses berdasarkan role admin dan customer.
5. Menggunakan prepared statement dan stored procedure untuk mengurangi risiko SQL Injection.
6. Menambahkan validasi input pada sisi backend untuk login, register, dan booking.
7. Menambahkan fitur rate limiting pada proses login.
8. Menambahkan endpoint logout agar token sesi dapat dihapus dari server.

9. Menambahkan security headers pada file konfigurasi backend.
10. Memindahkan credential sensitif ke file .env.
11. Menyusun checklist secure coding sebagai bukti evaluasi keamanan kode.

BAB II

PEMBAHASAN

2.1 Struktur Branch dan Repository

Pada minggu kedua, pengembangan sistem dilakukan menggunakan beberapa branch Git, yaitu main, admin-panel, authentication, booking, customer, database, develop, integration, payment, dan security-implementation. Penggunaan branch ini bertujuan untuk memisahkan pekerjaan berdasarkan fitur sehingga proses pengembangan lebih terstruktur.

Branch customer digunakan untuk pengembangan fitur pada sisi customer, sedangkan branch lain seperti admin-panel, authentication, database, dan payment digunakan untuk memisahkan fitur admin, login/register, struktur basis data, serta integrasi pembayaran. Pemisahan branch ini mendukung proses secure code review karena setiap perubahan dapat ditinjau berdasarkan fitur tertentu.

2.2 Struktur Folder Proyek

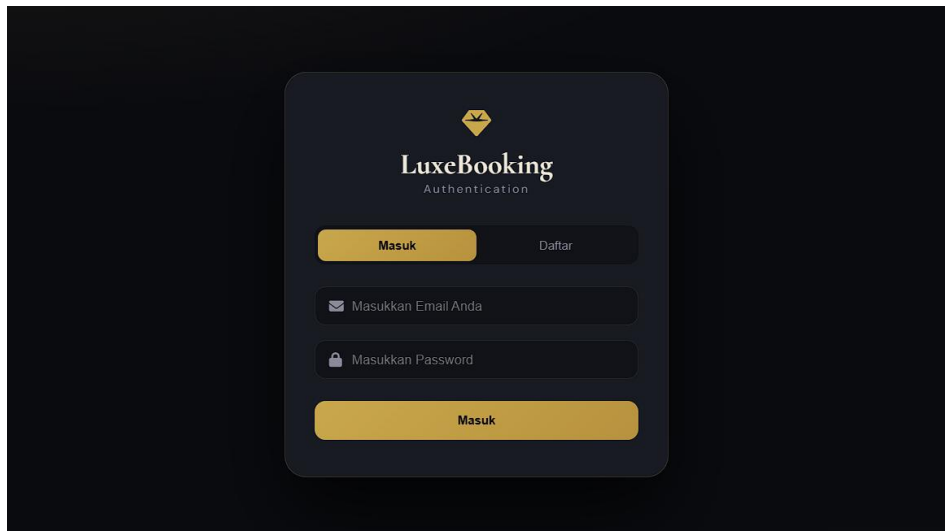
Struktur folder proyek LuxeBooking terdiri dari beberapa bagian utama, yaitu:

Tabel 2.1 Struktur Folder Proyek LuxeBooking

Folder/File	Keterangan
backend/	Berisi file backend seperti api.php dan config.php
database/	Berisi skema database dan stored procedure
frontend/	Berisi halaman antarmuka pengguna seperti login.html, admin.html, dan customer.html
docs/	Digunakan untuk menyimpan dokumentasi proyek
.env	Menyimpan credential sensitif seperti Midtrans server key dan client key
.env.example	Contoh konfigurasi environment tanpa credential asli
.gitignore	Mengecualikan file sensitif agar tidak masuk repository
README.md	Berisi penjelasan umum proyek

Struktur ini membantu pemisahan tanggung jawab antara frontend, backend, database, dan dokumentasi. Dengan adanya file .env, informasi sensitif tidak lagi ditulis langsung di dalam kode program, sehingga lebih aman ketika proyek dikelola menggunakan GitHub.

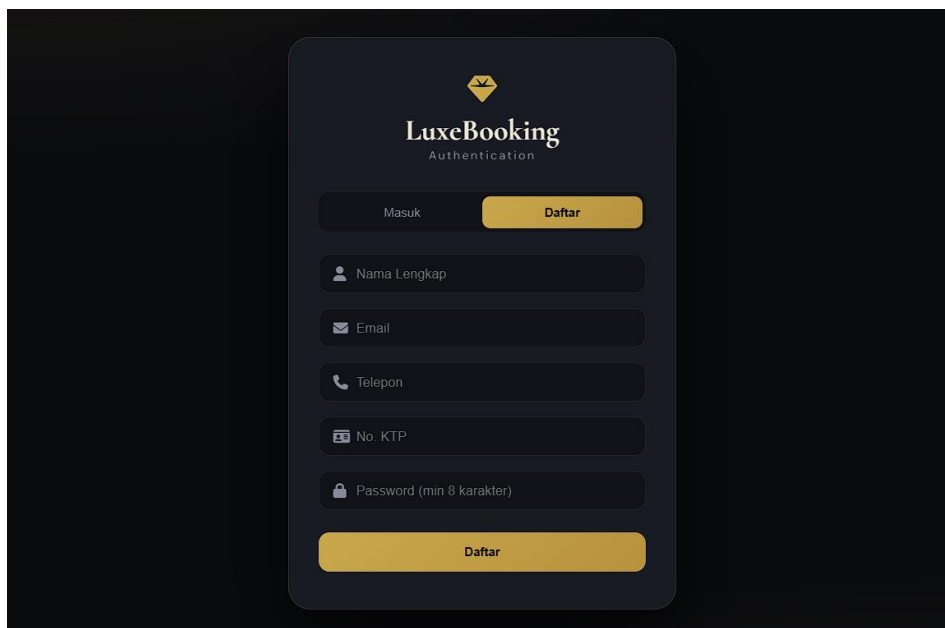
2.3 Tampilan Program



Gambar 2.1 Tampilan Halaman Login

Gambar 2.1 menunjukkan tampilan halaman login pada sistem LuxeBooking. Halaman ini digunakan oleh pengguna untuk masuk ke dalam sistem dengan memasukkan email dan password yang telah terdaftar. Tampilan login dibuat sederhana dengan dua pilihan utama, yaitu masuk dan daftar, sehingga pengguna dapat memilih apakah ingin login atau membuat akun baru.

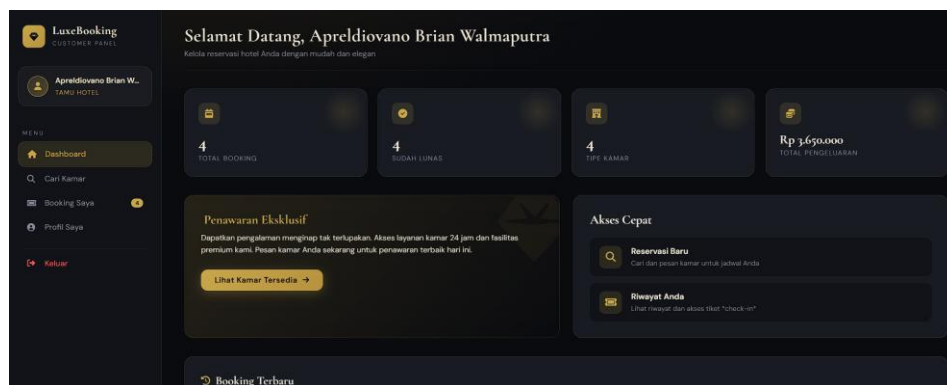
Halaman login ini menjadi bagian awal dari proses autentikasi sistem. Setelah pengguna memasukkan data login, sistem akan memverifikasi email dan password melalui backend. Jika data benar, pengguna akan diarahkan ke dashboard sesuai role, yaitu customer atau admin.



Gambar 2.2 Tampilan Halaman Register

Gambar 2.2 menampilkan form register yang digunakan oleh pengguna baru untuk membuat akun pada sistem LuxeBooking. Pada form ini, pengguna mengisi beberapa data seperti nama lengkap, email, nomor telepon, nomor identitas, dan password.

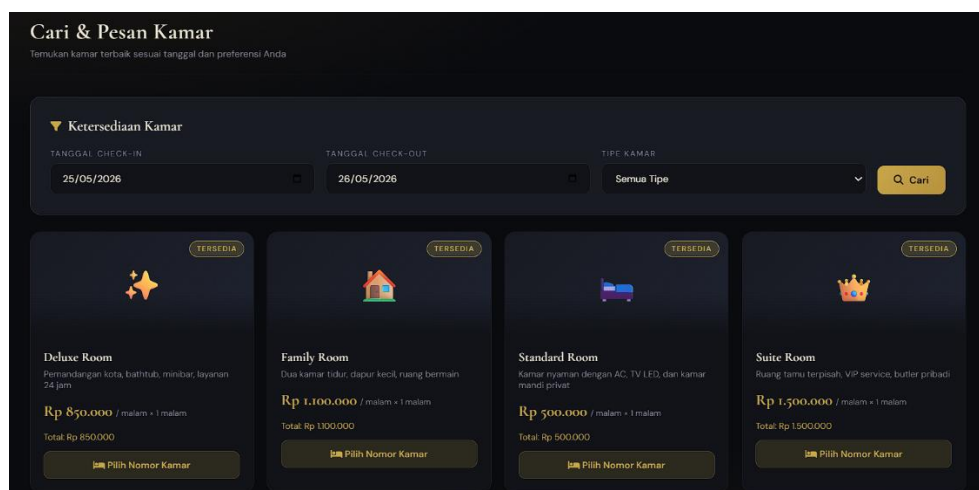
Fitur register ini terhubung dengan proses validasi backend. Data yang dimasukkan pengguna akan diperiksa terlebih dahulu, seperti kelengkapan data, format email, panjang password minimal 8 karakter, format nomor telepon, dan nomor identitas. Setelah data valid, password akan di-hash menggunakan bcrypt sebelum disimpan ke database.



Gambar 2.3 Tampilan Dashboard Customer

Gambar 2.3 menunjukkan tampilan dashboard customer setelah pengguna berhasil login. Pada halaman ini, customer dapat melihat ringkasan informasi seperti jumlah booking, status pembayaran, dan akses cepat ke fitur utama sistem.

Dashboard customer juga menyediakan navigasi menuju fitur pencarian kamar, riwayat booking, dan profil pengguna. Tampilan ini menunjukkan bahwa customer hanya diberikan akses terhadap fitur yang berkaitan dengan aktivitas pemesanan kamar dan data miliknya sendiri.



Pilih Nomor Kamar

Deluxe Room · 2026-05-25 → 2026-05-26

201 202 203 204 205

Batal Konfirmasi Pilihan

Konfirmasi Pembayaran

Kamar: Deluxe Room No. 201

Check-in: 2026-05-25

Check-out: 2026-05-26

Durasi: 1 malam

Harga/malam: Rp 850.000

Total Pembayaran: Rp 850.000

JUMLAH TAMU

1 Tamu

1 Tamu

2 Tamu

3 Tamu

4 Tamu

Gambar 2.4 Tampilan Pemesanan Kamar

Gambar 2.4 menampilkan proses pemesanan kamar oleh customer. Pada bagian ini, pengguna dapat memilih kamar, melihat detail harga, tanggal check-in dan check-out, durasi menginap, serta jumlah tamu sebelum melanjutkan ke proses pembayaran.

Tampilan ini berkaitan langsung dengan validasi input booking pada backend. Sebelum data booking diproses, sistem memeriksa kelengkapan data, format tanggal, urutan tanggal check-in dan check-out, serta batas jumlah tamu. Dengan demikian, proses booking tidak hanya berjalan secara fungsional, tetapi juga lebih aman dan terkontrol.

Booking Saya

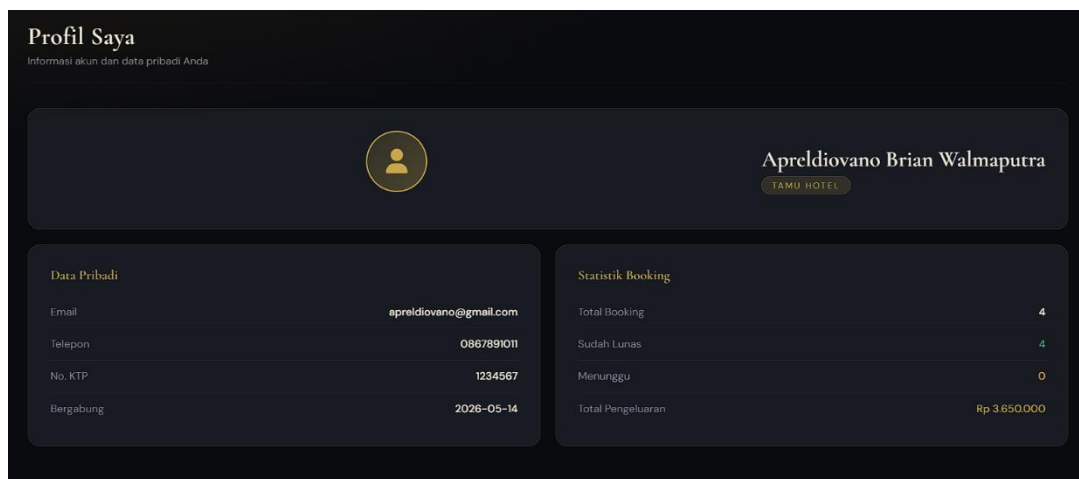
Riwayat dan status reservasi Anda

ID BOOKING	KAMAR	CHECK-IN	CHECK-OUT	TAMU	TOTAL	STATUS	BUKTI RESERVASI	METODE BAYAR	AKSI
78698718	Deluxe Room No.202	2026-05-13	2026-05-14	2	Rp 850.000	✓ Lunas	PV-78698718	credit_card	Selesai
78861616	Family Room No.401	2026-05-15	2026-05-16	1	Rp 1100.000	✓ Lunas	PV-78861616	credit_card	Selesai
79420493	Deluxe Room No.201	2026-05-22	2026-05-23	2	Rp 850.000	✓ Lunas	PV-79420493	credit_card	Selesai
79600264	Deluxe Room No.202	2026-05-24	2026-05-25	1	Rp 850.000	✓ Lunas	PV-79600264	credit_card	Selesai

Gambar 2.5 Tampilan Riwayat Booking Customer

Gambar 2.5 menunjukkan tampilan riwayat booking customer. Pada halaman ini, customer dapat melihat daftar pemesanan yang pernah dilakukan, termasuk informasi kamar, tanggal check-in, tanggal check-out, jumlah tamu, total pembayaran, status pembayaran, dan bukti reservasi.

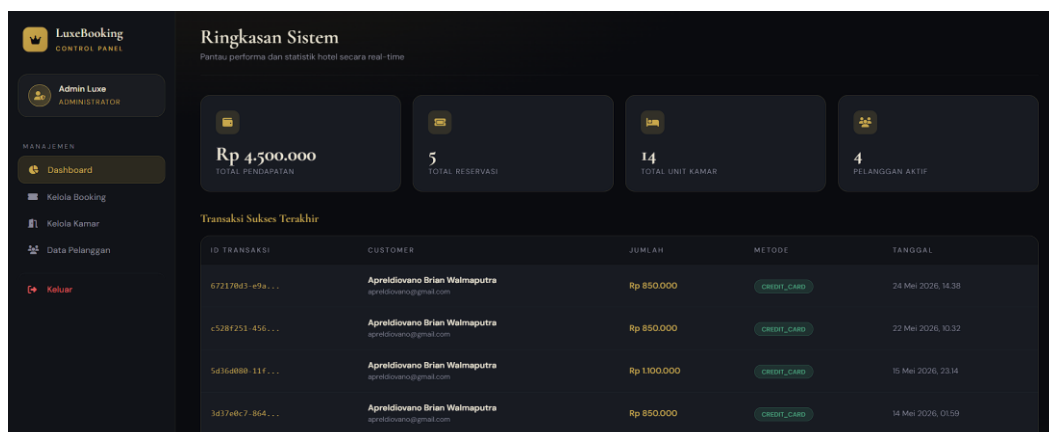
Fitur ini juga menunjukkan penerapan pembatasan akses data. Customer hanya dapat melihat data booking miliknya sendiri, bukan data booking milik pengguna lain. Hal ini mendukung penerapan prinsip keamanan dalam bentuk pembatasan akses berdasarkan identitas pengguna.



Gambar 2.6 Tampilan Profil Customer

Gambar 2.6 menampilkan halaman profil customer pada sistem LuxeBooking. Halaman ini berisi informasi pengguna seperti nama, email, nomor telepon, nomor identitas, tanggal bergabung, serta ringkasan aktivitas booking.

Tampilan profil ini digunakan untuk memberikan informasi akun kepada customer setelah berhasil login. Data yang ditampilkan bersifat terbatas pada pemilik akun tersebut, sehingga mendukung prinsip bahwa pengguna hanya dapat mengakses data yang berhubungan dengan dirinya sendiri.



Gambar 2.7 Tampilan Dashboard Admin

Gambar 2.7 menunjukkan tampilan dashboard admin pada sistem LuxeBooking. Dashboard ini menampilkan ringkasan sistem seperti total pendapatan, jumlah booking, jumlah pelanggan, serta informasi transaksi terbaru.

Berbeda dengan customer, admin memiliki akses yang lebih luas untuk mengelola data sistem. Tampilan ini menjadi bukti penerapan Role-Based Access Control, karena hanya pengguna dengan role admin yang dapat mengakses halaman dan fitur pengelolaan tersebut.

ID BOOKING	CUSTOMER	KAMAR	TANGGAL CHECK-IN	TOTAL BIAYA	STATUS	AKSI
BK1779608264	Apreldiovano Brian Walmaputra apreldiovano@gmail.com	Deluxe Room No.202	2026-05-24	Rp 850.000	Paid	Permanen
BK1779420693	Apreldiovano Brian Walmaputra apreldiovano@gmail.com	Deluxe Room No.201	2026-05-22	Rp 850.000	Paid	Permanen
BK1778861616	Apreldiovano Brian Walmaputra apreldiovano@gmail.com	Family Room No.401	2026-05-15	Rp 1.100.000	Paid	Permanen
BK1778698718	Apreldiovano Brian Walmaputra apreldiovano@gmail.com	Deluxe Room No.202	2026-05-13	Rp 850.000	Paid	Permanen
BK1778693785	Budi Santoso customer@demo.com	Deluxe Room No.201	2026-05-13	Rp 850.000	Paid	Permanen

Gambar 2.8 Tampilan Data Reservasi pada Dashboard Admin

Gambar 2.8 menampilkan halaman data reservasi pada dashboard admin. Melalui halaman ini, admin dapat melihat data booking yang dilakukan oleh customer, termasuk nama pelanggan, tipe kamar, tanggal check-in, total biaya, status pembayaran, dan aksi pengelolaan data.

ID	TIPE KAMAR	HARGA/MALAM	STOK	STATUS	AKSI
rm_dix...	Deluxe Room	Rp 850.000	5 Kamar	Aktif	[Edit] [Hapus]
rm_fam...	Family Room	Rp 1.100.000	2 Kamar	Aktif	[Edit] [Hapus]
rm_std...	Standard Room	Rp 500.000	5 Kamar	Aktif	[Edit] [Hapus]
rm_suite...	Suite Room	Rp 1.500.000	2 Kamar	Aktif	[Edit] [Hapus]

Gambar 2.9 Tampilan Inventori Kamar

Gambar 2.9 menunjukkan tampilan inventori kamar pada dashboard admin. Halaman ini digunakan untuk menampilkan daftar tipe kamar, harga per malam, jumlah unit kamar, status kamar, serta aksi untuk mengelola data kamar.

Fitur inventori kamar ini hanya dapat diakses oleh admin. Hal ini menunjukkan bahwa sistem telah membatasi fitur pengelolaan data kamar agar tidak dapat diakses oleh customer. Pembatasan tersebut mendukung penerapan Role-Based Access Control pada sistem LuxeBooking.

Data Pelanggan					
Daftar akun pelanggan hotel yang telah terdaftar					
NAMA LENGKAP	EMAIL	NO. HP	IDENTITAS (KTP)	BERGABUNG	AKSI
Testing 24 Mei 2026	24mei2026@gmail.com	123432156789	1234543218888	2026-05-24	 
Rafael	rafael@gmail.com	22098789	1233567	2026-05-22	 
Apreldiovano Brian Walmaputra	apreldiovano@gmail.com	0867891011	1234567	2026-05-14	 

Gambar 2.10 Tampilan Data Pelanggan

Gambar 2.10 menampilkan halaman data pelanggan pada dashboard admin. Halaman ini berisi daftar customer yang terdaftar pada sistem, seperti nama pelanggan, email, nomor telepon, nomor identitas, tanggal bergabung, dan aksi pengelolaan data pelanggan.

Tampilan data pelanggan ini menjadi bagian dari fitur administrasi sistem. Karena berisi data pengguna, fitur ini hanya boleh diakses oleh admin. Dengan demikian, halaman ini mendukung implementasi kontrol akses agar data customer tidak dapat dilihat atau dikelola oleh pengguna biasa.

2.4 Implementasi Autentikasi Login dan Register

Fitur autentikasi diimplementasikan melalui halaman login.html. Halaman ini menyediakan dua panel utama, yaitu panel masuk dan panel daftar. Pengguna dapat memasukkan email dan password untuk login, sedangkan pengguna baru dapat melakukan registrasi dengan mengisi nama lengkap, email, nomor telepon, nomor identitas, dan password.

Pada sisi backend, proses login dilakukan dengan mencari data user berdasarkan email menggunakan prepared statement, kemudian mencocokkan password menggunakan password_verify. Jika login berhasil, sistem membuat token acak menggunakan random_bytes, kemudian menyimpannya ke tabel sessions beserta waktu kedaluwarsa selama 24 jam.

Pada proses registrasi, backend mengambil data dari request berupa name, email, password, phone, dan id_number. Data tersebut kemudian divalidasi terlebih dahulu sebelum disimpan ke database. Validasi ini mencakup pemeriksaan data wajib, format email, panjang password minimal 8 karakter, format nomor telepon, dan format nomor identitas.

2.5 Implementasi Password Hashing

Password pengguna tidak disimpan dalam bentuk plaintext, melainkan di-hash menggunakan bcrypt. Pada proses registrasi, backend menggunakan fungsi password_hash dengan algoritma PASSWORD_BCRYPT. Pada progress terbaru, hashing password telah ditingkatkan dengan menambahkan parameter cost 12.

Contoh implementasi:

```
$hash = password_hash($pass, PASSWORD_BCRYPT, ['cost' => 12]);
```

Gambar 2.11 Potongan Kode Password Hashing Menggunakan Bcrypt Cost 12

Gambar 2.11 menunjukkan bahwa password pengguna diproses menggunakan bcrypt dengan cost 12 sebelum disimpan ke database. Dengan cara ini, password yang tersimpan berbentuk hash dan tidak dapat dibaca langsung oleh pihak lain.

2.6 Implementasi Manajemen Sesi

Manajemen sesi dilakukan menggunakan token yang disimpan pada tabel sessions. Setelah pengguna berhasil login, backend membuat cookie auth_token dan csrf_token. Cookie auth_token digunakan sebagai token autentikasi dan diberi atribut HttpOnly, sedangkan cookie csrf_token digunakan untuk validasi CSRF pada request penting. Bukti cookie yang terbentuk pada browser dapat dilihat pada Gambar 2.12.

auth_token	ebdd609609630fe79fb9c95f7d73f6276ea2...	localh...	/	2026-...	74	✓	Lax		Medi...
csrf_token	57f0a2c738dfb64857090a8a7537cc530996...	localh...	/	2026-...	74		Lax		Medi...
...	...	...	...	...	...	...	...	...	...

Gambar 2.12 Tampilan Cookie auth_token dan csrf_token pada Browser

Berdasarkan Gambar 2.12, cookie auth_token dan csrf_token berhasil dibuat setelah proses login. Cookie auth_token memiliki atribut HttpOnly dan SameSite=Lax, sehingga token autentikasi tidak dapat diakses langsung melalui JavaScript.

Setiap token tetap disimpan pada tabel sessions dengan waktu kedaluwarsa selama 24 jam. Ketika pengguna mengakses endpoint yang membutuhkan autentikasi, sistem membaca token dari cookie auth_token, kemudian mencocokkannya dengan data pada tabel sessions. Jika token valid dan belum kedaluwarsa, sistem mengizinkan akses sesuai role pengguna.

Sistem juga telah menambahkan endpoint logout untuk menghapus token dari tabel sessions dan menghapus cookie autentikasi dari browser. Dengan demikian, logout tidak hanya menghapus data pada sisi frontend, tetapi juga menginvalidasi sesi pada sisi server.

2.7 Implementasi CSRF Protection

Sistem LuxeBooking juga telah menerapkan perlindungan terhadap Cross-Site Request Forgery dengan menggunakan CSRF token. Pada saat login berhasil, backend membuat dua cookie, yaitu `auth_token` dan `csrf_token`. Cookie `auth_token` digunakan untuk autentikasi dan diberi atribut `HttpOnly`, sedangkan `csrf_token` digunakan oleh frontend untuk dikirim kembali melalui header `X-CSRF-Token`.

```
function validateCsrfToken() {
    $method = $_SERVER['REQUEST_METHOD'] ?? 'GET';

    if (in_array($method, ['POST', 'PUT', 'DELETE'])) {
        return;
    }

    $action = $_REQUEST['action'] ?? '';

    $excludedActions = ['login', 'register', 'me', 'logout'];

    if (in_array($action, $excludedActions)) {
        return;
    }

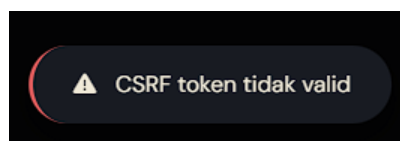
    $csrfCookie = $_COOKIE['csrf_token'] ?? '';
    $csrfHeader = $_SERVER['HTTP_X_CSRF_TOKEN'] ?? '';

    if (empty($csrfCookie) || empty($csrfHeader) || !hash_equals($csrfCookie, $csrfHeader)) {
        http_response_code(403);
        echo json_encode([
            'success' => false,
            'message' => 'CSRF token tidak valid'
        ]);
        exit;
    }
}
```

Gambar 2.13 Kode Validasi CSRF Token

Pada setiap request penting seperti booking, tambah kamar, update kamar, dan hapus kamar, backend akan memvalidasi kesesuaian antara cookie `csrf_token` dan header `X-CSRF-Token`. Jika token tidak ada atau tidak cocok, sistem akan menolak request dengan pesan “CSRF token tidak valid”.

Pengujian dilakukan dengan menghapus cookie `csrf_token`, kemudian mencoba menjalankan aksi penting pada sistem. Hasilnya, sistem menolak request dan menampilkan pesan “CSRF token tidak valid”. Hal ini menunjukkan bahwa validasi CSRF token telah berjalan.



Gambar 2.14 Hasil Pengujian CSRF Token Tidak Valid

Berdasarkan Gambar 2.14, sistem berhasil menolak request ketika CSRF token tidak valid. Hal ini menunjukkan bahwa mekanisme CSRF protection telah berjalan sesuai dengan tujuan implementasi keamanan.

2.8 Implementasi Role-Based Access Control

Sistem LuxeBooking menerapkan dua role utama, yaitu admin dan customer. Admin memiliki akses untuk mengelola data booking, kamar, pelanggan, transaksi, dan statistik dashboard. Customer memiliki akses untuk mencari kamar, melakukan booking, melihat riwayat booking, dan melihat profil.

Pembatasan akses diterapkan di backend dengan memeriksa nilai role dari user yang sedang login. Endpoint seperti `add_room`, `update_room`, `delete_room`, `get_stats`, `get_transactions`, dan `get_customers` hanya dapat diakses oleh admin. Jika user yang tidak memiliki role admin mencoba mengakses endpoint tersebut, sistem akan menolak akses.

Dengan penerapan ini, sistem sudah menerapkan prinsip Role-Based Access Control dan least privilege, yaitu setiap pengguna hanya diberikan hak akses sesuai kebutuhannya.

```
case 'add_room':
    $user = authenticate($pdo);
    if ($user['role'] !== 'admin') { echo json_encode(['success'=>false, 'message'=>'Akses ditolak']); break; }

    $id = 'rm_' . bin2hex(random_bytes(4));
    $type = trim($input['type'] ?? '');
    $price = $input['price_per_night'] ?? 0;
    $desc = trim($input['description'] ?? '');
    $emoji = $input['emoji'] ?? '🛏️';
    $roomNumbers = $input['room_numbers'] ?? ''; // Format: "101, 102, 103"
```

Gambar 2.15 Potongan Kode Role-Based Access Control pada Endpoint Admin

2.9 Implementasi Validasi Input

Validasi input dilakukan pada sisi frontend dan backend. Pada sisi frontend, sistem memeriksa kelengkapan data login, register, tanggal check-in, tanggal check-out, jumlah tamu, dan data kamar. Validasi ini membantu pengguna agar tidak salah memasukkan data.

```

if (empty($unitId) || empty($checkin) || empty($checkout)) {
    echo json_encode([
        'success' => false,
        'message' => 'Data booking tidak lengkap'
    ]);
    break;
}

if (strtotime($checkin) === false || strtotime($checkout) === false) {
    echo json_encode([
        'success' => false,
        'message' => 'Format tanggal tidak valid'
    ]);
    break;
}

if (strtotime($checkin) >= strtotime($checkout)) {
    echo json_encode([
        'success' => false,
        'message' => 'Tanggal checkout harus setelah check-in'
    ]);
    break;
}

if ($guests < 1 || $guests > 10) {
    echo json_encode([
        'success' => false,
        'message' => 'Jumlah tamu tidak valid'
    ]);
    break;
}

```

Gambar 2.16 Potongan Kode Validasi Input Booking

Pada progress terbaru, validasi backend juga telah diperkuat. Pada proses login, sistem memeriksa apakah email dan password sudah diisi serta apakah format email valid. Pada proses register, sistem memeriksa nama, email, password, nomor telepon, dan nomor identitas. Pada proses booking, sistem memeriksa kelengkapan data booking, format tanggal, urutan tanggal check-in dan check-out, serta jumlah tamu.

Contoh validasi booking yang diterapkan adalah memastikan tanggal check-out harus setelah tanggal check-in. Jika data tidak valid, backend akan mengembalikan pesan error dan proses booking tidak dilanjutkan ke stored procedure.

2.10 Implementasi Rate Limiting Login

Pada progress terbaru, sistem telah menambahkan fitur rate limiting pada proses login. Fitur ini digunakan untuk membatasi percobaan login gagal dalam rentang waktu tertentu. Implementasi dilakukan dengan menambahkan tabel baru bernama `login_attempts`.

Tabel `login_attempts` menyimpan data email, alamat IP, dan waktu percobaan login gagal. Ketika pengguna salah memasukkan password, sistem akan mencatat percobaan tersebut ke tabel `login_attempts`. Jika percobaan login gagal mencapai 5 kali

dalam 10 menit, sistem akan menolak proses login sementara dan menampilkan pesan “Terlalu banyak percobaan login. Coba lagi nanti.”

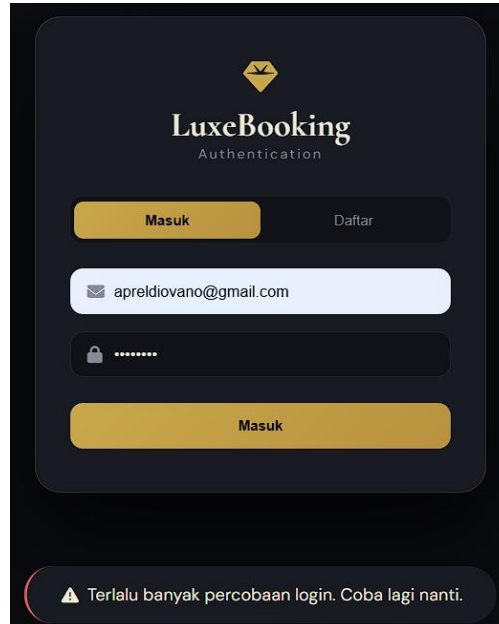
```
// 2. Rate limiting login
$ip = $_SERVER['REMOTE_ADDR'] ?? 'unknown';

$checkAttempts = $pdo->prepare("
    SELECT COUNT(*)
    FROM login_attempts
    WHERE email = ?
    AND ip_address = ?
    AND attempted_at > DATE_SUB(NOW(), INTERVAL 10 MINUTE)
");
$checkAttempts->execute([$email, $ip]);

if ($checkAttempts->fetchColumn() >= 5) {
    http_response_code(429);
    echo json_encode([
        'success' => false,
        'message' => 'Terlalu banyak percobaan login. Coba lagi nanti.'
    ]);
    break;
}
```

Gambar 2.17 Kode Rate Limiting Login

Pengujian dilakukan dengan memasukkan password yang salah beberapa kali. Setelah batas percobaan tercapai, sistem menolak proses login sementara. Hasil pengujian rate limiting dapat dilihat pada Gambar 2.18.



Gambar 2.18 Tampilan Pesan Rate Limiting Login

Berdasarkan Gambar 2.18, sistem menampilkan pesan “Terlalu banyak percobaan login. Coba lagi nanti.” Hal ini menunjukkan bahwa pembatasan percobaan login telah berjalan.

2.11 Pencegahan SQL Injection

Pencegahan SQL Injection dilakukan dengan menggunakan prepared statement pada query database. Query seperti pencarian user, tambah kamar, update kamar, cek ketersediaan kamar, pengambilan booking, penghapusan data, dan pencatatan login attempt menggunakan parameter ?, sehingga input pengguna tidak langsung digabungkan ke string SQL. Salah satu implementasinya terdapat pada proses login, ketika sistem mencari user berdasarkan email. Potongan kode prepared statement dapat dilihat pada Gambar 2.19.

```
// 3. Cek user berdasarkan email
$stmt = $pdo->prepare("SELECT * FROM users WHERE email = ? AND deleted_at IS NULL");
$stmt->execute([$email]);
$user = $stmt->fetch();

// 4. Jika password benar, buat token session
if ($user && password_verify($pass, $user['password'])) {
    $token = bin2hex(random_bytes(32));
}
```

Gambar 2.19 Potongan Kode Prepared Statement pada Query Login

Gambar 2.19 menunjukkan bahwa input email pengguna tidak digabungkan langsung ke query SQL, melainkan dikirim sebagai parameter. Dengan demikian, risiko SQL Injection dapat dikurangi.

2.12 Implementasi Stored Procedure Booking Aman

Stored procedure `sp_create_secure_booking` digunakan untuk membuat booking baru secara aman. Prosedur ini melakukan beberapa langkah, yaitu mengambil harga kamar, memeriksa konflik booking pada tanggal yang dipilih, menghitung jumlah malam, menghitung total harga, dan menyimpan data booking dengan status pending.

Stored procedure ini menggunakan transaksi database dengan `START TRANSACTION`, `COMMIT`, dan `ROLLBACK`. Selain itu, penggunaan `FOR UPDATE` membantu mengunci data kamar saat proses booking berlangsung sehingga dapat mengurangi risiko double booking. Dengan mekanisme ini, sistem dapat memastikan bahwa satu unit kamar tidak dapat dipesan oleh dua customer pada tanggal yang bertabrakan.

```

1  USE luxebooking;
2
3  DELIMITER $$
4
5  DROP PROCEDURE IF EXISTS `sp_create_secure_booking` $$
6
7  CREATE PROCEDURE `sp_create_secure_booking` (
8      IN p_customer_id VARCHAR(36),
9      IN p_room_unit_id VARCHAR(36),
10     IN p_checkin DATE,
11     IN p_checkout DATE,
12     IN p_guests SMALLINT,
13     OUT p_booking_id VARCHAR(36),
14     OUT p_total_price DECIMAL(14,2),
15     OUT p_status VARCHAR(50)
16 )
17 BEGIN
18     DECLARE v_conflict INT DEFAULT 0;
19     DECLARE v_price DECIMAL(12,2) DEFAULT 0;
20     DECLARE v_nights SMALLINT DEFAULT 0;
21
22     START TRANSACTION;
23
24     SELECT r.price_per_night INTO v_price
25     FROM room_units u
26     JOIN rooms r ON u.room_id = r.id
27     WHERE u.id = p_room_unit_id FOR UPDATE;
28
29     SELECT COUNT(*) INTO v_conflict
30     FROM bookings
31     WHERE room_unit_id = p_room_unit_id
32     AND payment_status IN ('pending', 'paid')
33     AND p_checkin < checkout_date
34     AND p_checkout > checkin_date;
35
36     IF v_conflict > 0 THEN
37         ROLLBACK;
38         SET p_status = 'FAILED_ALREADY_BOOKED';
39     ELSE
40         SET p_booking_id = CONCAT('BK_', UNIX_TIMESTAMP());
41         SET v_nights = DATEDIFF(p_checkout, p_checkin);
42         SET p_total_price = v_nights * v_price;
43
44         INSERT INTO bookings (id, customer_id, room_unit_id, checkin_date, checkout_date, nights, guests, total_price, payment_status)
45         VALUES (p_booking_id, p_customer_id, p_room_unit_id, p_checkin, p_checkout, v_nights, p_guests, p_total_price, 'pending');
46
47         COMMIT;
48         SET p_status = 'SUCCESS';
49     END IF;
50 END $$
51
52 DELIMITER ;

```

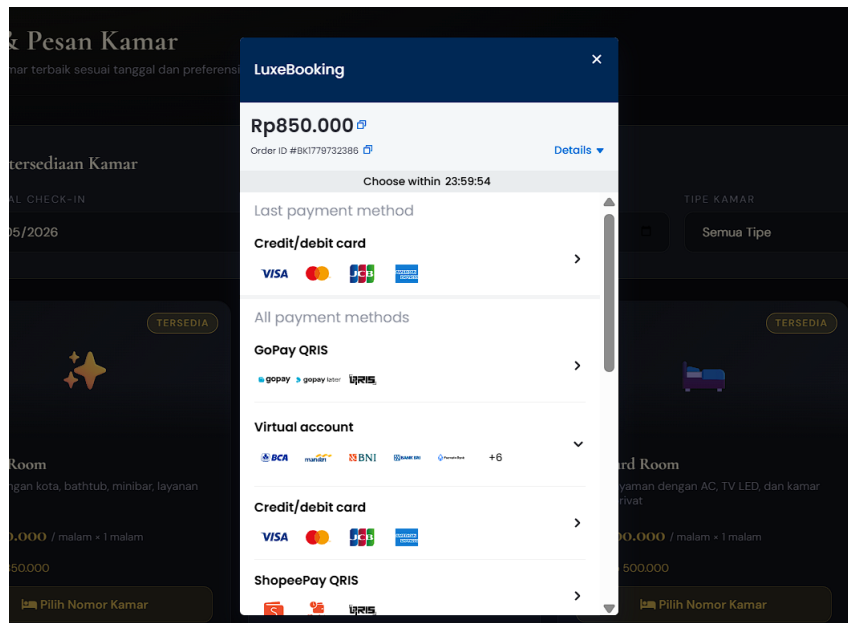
Gambar 2.20 Potongan Kode Stored Procedure Booking Aman

Berdasarkan Gambar 2.20, stored procedure melakukan pengecekan konflik booking terlebih dahulu. Jika kamar sudah dipesan pada tanggal yang bertabrakan, transaksi dibatalkan menggunakan ROLLBACK.

2.13 Integrasi Payment Gateway Midtrans

Sistem LuxeBooking terintegrasi dengan payment gateway Midtrans melalui fitur Snap. Pada sisi customer, setelah pengguna memilih kamar dan melakukan booking, sistem meminta Snap token dari backend, kemudian menampilkan halaman pembayaran Midtrans.

Pada sisi backend, sistem memproses callback pembayaran dan melakukan verifikasi signature untuk memastikan notifikasi benar-benar berasal dari Midtrans. Jika pembayaran berhasil, sistem mengubah status booking menjadi paid, membuat e-voucher, dan menyimpan data transaksi.



Gambar 2.21 Tampilan Midtrans Saat Pembayaran

Pada progress terbaru, credential Midtrans seperti server key dan client key tidak lagi ditulis langsung di config.php, tetapi dipindahkan ke file .env. File .env juga sudah dikecualikan dari repository melalui .gitignore, sehingga credential asli tidak ikut terunggah ke GitHub.

2.14 Implementasi Security Headers

Security headers merupakan bagian penting untuk mengurangi risiko serangan berbasis browser seperti XSS, clickjacking, MIME sniffing, dan penyalahgunaan browser API. Pada progress terbaru, security headers telah ditambahkan pada file config.php.

```
header("Content-Type: application/json");
header("X-Frame-Options: SAMEORIGIN");
header("X-Content-Type-Options: nosniff");
header("Referrer-Policy: strict-origin-when-cross-origin");
header("Permissions-Policy: camera=(), microphone=(), geolocation=());
```

Gambar 2.22 Potongan Kode Security Headers pada config.php

Selain itu, sistem juga menambahkan Content Security Policy untuk membatasi sumber konten yang diperbolehkan, seperti sumber script, style, font, gambar, dan koneksi eksternal. Karena sistem menggunakan Midtrans, Google Fonts, dan Font Awesome, maka sumber tersebut dimasukkan ke dalam kebijakan CSP.

2.15 Pencegahan Cross-Site Scripting

Pada sisi frontend, beberapa data dari database ditampilkan menggunakan innerHTML. Untuk membantu mengurangi risiko Cross-Site Scripting, sistem menambahkan fungsi escapeHTML() pada file admin.html dan customer.html.

Fungsi ini digunakan untuk mengubah karakter khusus seperti <, >, ", ', dan & menjadi format HTML entity. Dengan demikian, data yang berasal dari pengguna atau database tidak langsung dieksekusi sebagai HTML oleh browser.

Contoh fungsi:

A screenshot of a code editor showing a JavaScript function named escapeHTML. The function takes a string 'str' as input and returns a new string where special characters are escaped. The code is as follows:

```
function escapeHTML(str) {  
    return String(str ?? '').replace(/[<>"']/g, s => ({  
        '&': '&amp;',  
        '<': '&lt;',  
        '>': '&gt;',  
        '"': '&quot;',  
        "'": '&#039;',  
    }[s]));  
}
```

Gambar 2.23 Kode Fungsi escapeHTML untuk Pencegahan XSS

Gambar 2.23 menunjukkan fungsi escapeHTML() yang digunakan untuk mengubah karakter khusus menjadi HTML entity. Fungsi ini membantu mencegah input yang mengandung script dieksekusi oleh browser ketika data ditampilkan menggunakan innerHTML.

2.16 Secure Error Handling

Sistem sudah menggunakan beberapa pesan error yang bersifat umum, seperti “Email atau password salah”, “Koneksi database gagal”, “Terjadi kesalahan sistem”, “Format email tidak valid”, dan “Terlalu banyak percobaan login. Coba lagi nanti.” Pesan error tersebut tidak menampilkan detail teknis seperti struktur query, path file server, atau stack trace.

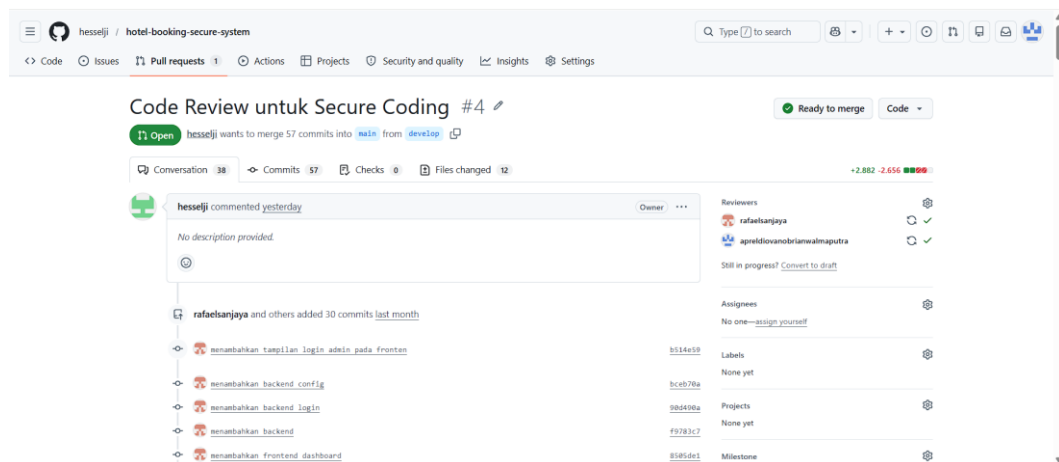
Hal ini penting karena pesan error yang terlalu detail dapat dimanfaatkan oleh penyerang untuk mengetahui struktur sistem. Dengan menggunakan pesan error yang umum, sistem dapat tetap memberikan informasi kepada pengguna tanpa membocorkan detail internal aplikasi.

2.17 Secure Code Review

Secure code review dilakukan untuk meninjau perubahan kode yang telah dibuat pada minggu kedua. Proses review dilakukan melalui fitur Pull Request pada GitHub agar setiap perubahan dapat diperiksa sebelum digabungkan ke branch utama. Review

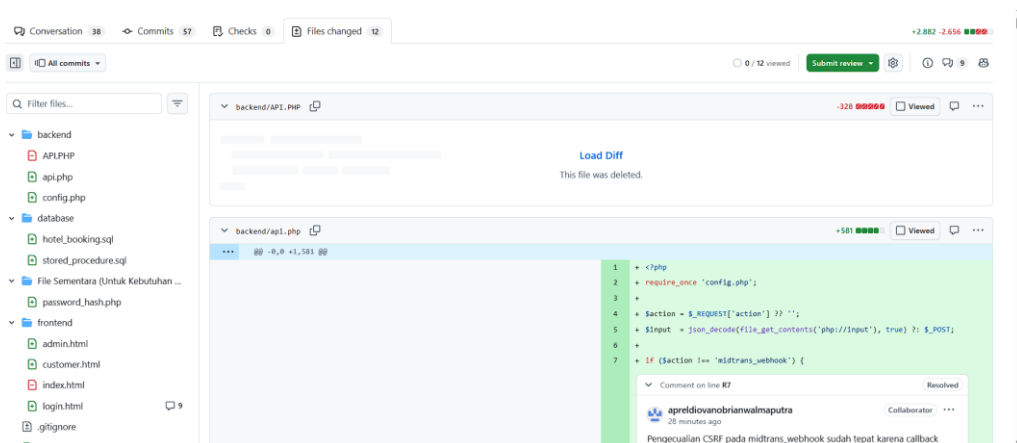
difokuskan pada bagian keamanan seperti autentikasi, manajemen sesi, CSRF protection, security headers, validasi input, penyimpanan credential, dan pencegahan XSS.

Pada proses ini, file yang ditinjau meliputi backend/config.php, backend/api.php, frontend/login.html, frontend/admin.html, dan frontend/customer.html. File config.php diperiksa karena berisi konfigurasi security headers, cookie HttpOnly, SameSite, CSRF token, serta pemindahan credential ke file .env. File api.php diperiksa karena berisi proses login, register, logout, validasi input, rate limiting, dan penggunaan prepared statement. File frontend diperiksa untuk memastikan token tidak lagi disimpan di sessionStorage, request menggunakan cookie, dan output data menggunakan fungsi escapeHTML().



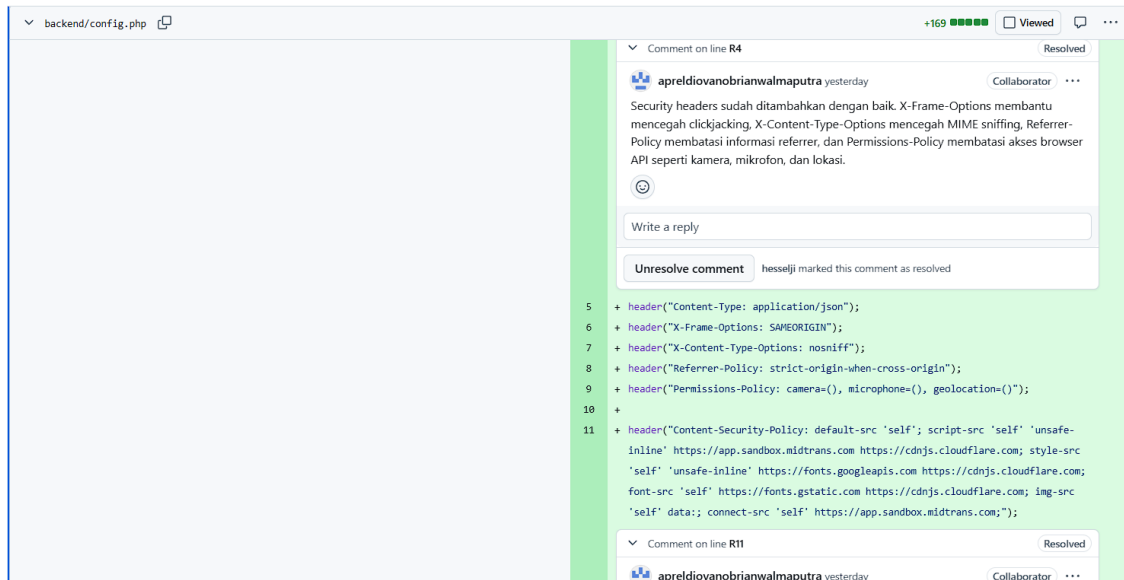
Gambar 2.24 Halaman Pull Request Code Review

Gambar 2.24 menunjukkan proses code review yang dilakukan melalui Pull Request pada GitHub. Pull Request digunakan untuk meninjau perubahan kode sebelum digabungkan ke branch utama.



Gambar 2.25 Tampilan Files Changed pada Pull Request

Gambar 2.25 menunjukkan daftar file yang mengalami perubahan dan diperiksa pada proses code review. Pemeriksaan dilakukan untuk memastikan perubahan kode sudah sesuai dengan prinsip secure coding minggu kedua.



Gambar 2.26 Komentar Secure Code Review pada File config.php

Gambar 2.26 menunjukkan komentar review pada file config.php. Bagian ini ditinjau karena berhubungan dengan penerapan security headers, cookie HttpOnly, SameSite, validasi CSRF token, dan konfigurasi credential menggunakan .env.

Berdasarkan hasil review, sebagian besar implementasi keamanan telah sesuai dengan kebutuhan minggu kedua. Sistem sudah menggunakan password hashing, token acak, cookie HttpOnly, SameSite=Lax, CSRF token, RBAC, validasi input, prepared statement, security headers, dan fungsi escapeHTML(). Beberapa catatan seperti pengurangan penggunaan unsafe-inline pada Content Security Policy dan penghapusan fallback token dari body request dapat dijadikan rencana hardening pada minggu berikutnya.

Tabel 2.2 Hasil Secure Code Review

No	File yang Direview	Fokus Review	Hasil
1	backend/config.php	Security headers, cookie HttpOnly, SameSite, CSRF, .env	Sesuai
2	backend/api.php	Login, register, logout, rate limiting, validasi input	Sesuai
3	frontend/login.html	Penyimpanan token dan request login	Sesuai
4	frontend/admin.html	RBAC admin, CSRF header, output escaping	Sesuai
5	frontend/customer.html	Cookie auth, CSRF header, data customer	Sesuai

Berdasarkan Tabel 2.2, file utama yang berkaitan dengan keamanan telah melalui proses review. Hasil review menunjukkan bahwa implementasi keamanan inti telah diterapkan, seperti penggunaan cookie HttpOnly, CSRF token, validasi input, RBAC, dan

pencegahan XSS. Catatan perbaikan lanjutan akan dilanjutkan pada tahap security testing dan hardening.

2.18 Checklist Secure Coding Minggu 2

Tabel 2.3 Checklist Secure Coding Minggu 2

No	Aspek Keamanan	Status	Keterangan
1	Password menggunakan hashing	Done	Sudah memakai bcrypt
2	Password tidak disimpan plaintext	Done	Password tersimpan dalam bentuk hash
3	Bcrypt cost 12	Done	Sudah memakai ['cost' => 12]
4	Login menggunakan verifikasi password	Done	Sudah memakai password_verify
5	Token dibuat secara acak	Done	Menggunakan random_bytes
6	Token memiliki expiry	Done	Token berlaku 24 jam
7	Logout invalidasi token di server	Done	Endpoint logout menghapus token dari tabel sessions
8	Token disimpan HttpOnly cookie	Done	Token disimpan pada cookie auth_token dengan atribut HttpOnly
9	SameSite cookie	Done	Cookie menggunakan SameSite=Lax
10	CSRF protection	Done	Menggunakan cookie csrf_token dan header X-CSRF-Token
11	RBAC admin/customer	Done	Endpoint admin mengecek role
12	Customer hanya melihat booking miliknya	Done	Query booking customer memakai customer_id
13	Prepared statement	Done	Query menggunakan PDO prepare
14	Stored procedure booking	Done	Booking memakai sp_create_secure_booking
15	Pencegahan double booking	Done	Ada pengecekan konflik tanggal
16	Validasi input frontend	Done	Ada validasi form dan tanggal
17	Validasi input backend	Done	Login, register, dan booking sudah divalidasi

18	Pencegahan XSS output	Done	Ditambahkan fungsi escapeHTML()
19	Security headers	Done	Ditambahkan di config.php
20	Rate limiting login	Done	Menggunakan tabel login_attempts
21	Secret tidak hardcoded	Done	Credential dipindahkan ke .env
22	Error message tidak membocorkan detail sistem	Done	Pesan error bersifat umum
23	Payment callback diverifikasi	Done	Callback Midtrans diverifikasi dengan signature
24	Soft delete customer	Done	Customer dinonaktifkan dengan deleted_at
25	Branch terpisah per fitur	Done	Ada branch authentication, booking, customer, payment, dan lainnya

2.19 Hambatan dan Solusi

Pada pengerjaan minggu kedua, terdapat beberapa hambatan yang ditemukan. Pertama, beberapa kontrol keamanan awalnya masih belum sepenuhnya diterapkan, seperti logout yang hanya menghapus token pada frontend, credential Midtrans yang masih hardcoded, serta belum adanya rate limiting login. Kedua, validasi backend masih perlu diperkuat agar tidak hanya bergantung pada validasi frontend.

Solusi yang dilakukan adalah menambahkan endpoint logout pada backend, memindahkan credential ke file .env, menambahkan security headers pada config.php, memperkuat validasi input pada api.php, membuat tabel login_attempts, serta menambahkan fungsi escapeHTML() pada frontend. Dengan solusi tersebut, implementasi keamanan sistem menjadi lebih sesuai dengan materi Secure Software Engineering minggu kedua.

2.20 Lampiran

Link Github: <https://github.com/hesselji/hotel-booking-secure-system>

BAB III

KESIMPULAN

Pada progress minggu kedua, sistem LuxeBooking telah mengalami perkembangan signifikan dari sisi implementasi fitur keamanan inti. Sistem sudah memiliki fitur login, register, autentikasi berbasis token, role admin dan customer, pengelolaan booking, pengelolaan kamar, pengelolaan customer, stored procedure booking, serta integrasi payment gateway Midtrans.

Dari sisi keamanan, sistem telah menerapkan password hashing menggunakan bcrypt dengan cost 12, verifikasi password menggunakan password_verify, token acak menggunakan random_bytes, manajemen sesi melalui tabel sessions, penyimpanan token pada cookie HttpOnly, penggunaan atribut SameSite=Lax, serta endpoint logout yang menghapus token dari server. Selain itu, sistem juga telah menerapkan CSRF token melalui cookie csrf_token dan header X-CSRF-Token.

Sistem juga telah menerapkan Role-Based Access Control, prepared statement untuk mencegah SQL Injection, stored procedure untuk mencegah double booking, validasi input backend, security headers, rate limiting login, pemindahan credential sensitif ke file .env, serta fungsi escapeHTML() untuk membantu mencegah Cross-Site Scripting.

Berdasarkan hasil pengujian manual, cookie auth_token dan csrf_token berhasil dibuat setelah login. Cookie auth_token sudah memiliki atribut HttpOnly dan SameSite=Lax, sedangkan pengujian CSRF menunjukkan bahwa sistem menolak request ketika csrf_token tidak valid. Dengan demikian, sebagian besar kontrol keamanan inti pada minggu kedua telah berhasil diimplementasikan.

Meskipun demikian, sistem masih dapat ditingkatkan pada minggu berikutnya melalui pengujian keamanan yang lebih menyeluruh, seperti SAST, DAST menggunakan OWASP ZAP, pengujian IDOR, pengujian XSS lanjutan, pengujian SQL Injection, serta penyusunan vulnerability report dengan CVSS. Tahap tersebut akan menjadi fokus pada minggu ketiga sesuai materi Security Testing.